

DEDOMO

Adempimenti GDPR — Schema procedurale

Versione 1.0 · 27/06/2026 · Uso interno

Contesto applicativo

Dedomo è un SaaS B2B per gestori di strutture ricettive (case vacanza, B&B) in Italia. Tratta dati personali degli ospiti esclusivamente per adempiere agli obblighi di legge in materia di pubblica sicurezza: invio schedine alla Polizia di Stato (Alloggiati Web), movimentazioni regionali (Ross 1000) e calcolo imposta di soggiorno. Il gestore della struttura è il Titolare del trattamento; Dedomo agisce come Responsabile del trattamento (art. 28 GDPR).

Legenda colori nelle sezioni:

BASE GIURIDICA

MISURA TECNICA

PENDENTE

AUTOMAZIONE

1. Soggetti coinvolti nel trattamento

Soggetto	Ruolo GDPR / Note
Gestore struttura ricettiva (cliente Dedomo)	Titolare del trattamento — decide finalità e mezzi
Ospite della struttura	Interessato — i cui dati personali vengono raccolti
Dedomo SaaS (pama69@gmail.com)	Responsabile del trattamento (art. 28) — deve firmare DPA con ogni gestore
Polizia di Stato — Alloggiati Web	Destinatario istituzionale — obbligo art. 109 TULPS
Regione — Ross 1000 / Turismo 5	Destinatario istituzionale — obbligo D.Lgs. 79/2011
Comune — Imposta di Soggiorno	Destinatario istituzionale — obbligo comunale
MongoDB Atlas (AWS Frankfurt)	Sub-responsabile — storage dati in UE
Railway (hosting app)	Sub-responsabile — esecuzione codice, EU region
Resend (email)	Sub-responsabile — email transazionali
OpenAI (OCR documenti)	Sub-responsabile — analisi immagine documento; richiede DPA
Stripe (pagamenti)	Titolare autonomo per dati billing — no dati ospiti

2. Categorie di dati trattati

Categoria / Campo	Finalità / Destinatario
Cognome, Nome	Alloggiati Web, Ross 1000
Sesso	Alloggiati Web
Data di nascita	Alloggiati Web, Ross 1000
Luogo / Comune di nascita	Alloggiati Web
Stato / Paese di nascita	Alloggiati Web

Cittadinanza / Nazionalità

	Alloggiati Web
Tipo documento (CI, Passaporto, Patente...)	Alloggiati Web
Numero documento	Alloggiati Web, Ross 1000
Stato rilascio documento	Alloggiati Web
Email ospite (facoltativa)	Email benvenuto + pagina ospite — legittimo interesse
Immagine documento (OCR)	Elaborata da OpenAI, NON conservata — solo campi estratti
Data arrivo / partenza	Alloggiati Web, Ross 1000, Imposta Soggiorno
Email gestore / dati account	Gestione account Dedomo — base: contratto art. 6(1)(b)
Dati pagamento (Stripe)	Fatturazione abbonamento — gestiti da Stripe, non da Dedomo

3. Basi giuridiche del trattamento (art. 6 GDPR)

3.1 Dati degli ospiti — Obbligo legale [art. 6(1)(c)]

Il trattamento è necessario per adempiere un obbligo legale cui è soggetto il Titolare.

Norme di riferimento:

- Art. 109 T.U.L.P.S. (R.D. 773/1931) — comunicazione PS entro 24h dall'arrivo
- D.Lgs. 286/1998 art. 7 — dichiarazione obbligatoria per cittadini stranieri
- D.Lgs. 79/2011 (Codice del Turismo) — statistiche regionali Ross 1000
- Delibere comunali — imposta di soggiorno

NOTA: il consenso dell'ospite NON è la base giuridica. La checkbox nel form ospite vale come presa d'atto dell'informativa, NON come consenso al senso dell'art. 7 GDPR.

3.2 Dati account gestore — Contratto [art. 6(1)(b)]

Esecuzione del contratto SaaS tra Dedomo e il gestore della struttura.

3.3 Email ospite facoltativa — Legittimo interesse [art. 6(1)(f)]

Il gestore ha interesse legittimo a comunicare informazioni pre-soggiorno all'ospite.
L'ospite non è obbligato a fornire l'email; in assenza, nessuna email viene inviata.

4. Flusso dati — Ciclo di vita del dato ospite

- 1

RACCOLTA
L'host crea un check-in in app (Checkin.jsx) oppure invia link remoto all'ospite (RemoteCheckin.jsx). Il form ospite raccoglie dati anagrafici e documento. Trasmissione via HTTPS.
- 2

OCR (opzionale)
L'ospite fotografa il documento. L'immagine viene elaborata da OpenAI Vision server-side. OpenAI restituisce i campi estratti; l'immagine NON viene mai conservata da Dedomo.
- 3

VALIDAZIONE HOST (solo remoto)
Per il check-in remoto: l'host rivede i dati inviati dall'ospite in Archive e deve autorizzarli esplicitamente. Nessun invio automatico senza autorizzazione.
- 4

INVIO AI PORTALI
Alloggiati Web (SOAP/HTTPS) — schedine Polizia di Stato.
Ross 1000 (SOAP/CSV) — movimentazioni regionali.
APScheduler: invio automatico alle 23:59 (ora italiana) del giorno di arrivo.
- 5

ARCHIVIAZIONE
Dati in MongoDB Atlas (AWS Frankfurt, EU). Accessibili solo all'host autenticato. Conservazione: 3 anni dalla data di

invio.

6 ANONIMIZZAZIONE (automatica)

Job APScheduler — 1° del mese, ore 03:00:

- Checkins >3 anni: cognome/nome/data_nascita/luogo_nascita/numero_documento → '[anonimizzato]'
- Remote_checkins completati/falliti >3 anni → eliminati

Base: art. 5(1)(e) GDPR — limitazione della conservazione.

7 CANCELLAZIONE ACCOUNT

L'host richiede cancellazione da Settings → Zona pericolosa (doppia conferma).

Vengono eliminati: strutture, checkins, remote_checkins, sessioni, token ospite, abbonamento.

Payment_transactions: anonimizzate (email → [deleted]) per obbligo fiscale (10 anni).

5. Diritti degli interessati (artt. 15-22 GDPR)

Diritto	Come viene gestito in Dedomo
Art. 15 — Accesso	L'ospite si rivolge al gestore (Titolare). Il gestore vede tutti i dati in Archive.
Art. 16 — Rettifica	Il gestore modifica i dati prima dell'invio ai portali. Dopo l'invio: contatto diretto con Alloggiati Web.
Art. 17 — Cancellazione	Limitato dall'art. 6(1)(c): l'obbligo legale prevale sui dati già inviati alla PS. Anonimizzazione dopo 3 anni.
Art. 18 — Limitazione	Gestita manualmente dal gestore tramite supporto Dedomo.
Art. 20 — Portabilità	Dati esportabili in JSON via API o su richiesta al supporto.
Art. 21 — Opposizione	Non applicabile: base giuridica è obbligo legale, non legittimo interesse.
Art. 77 — Reclamo al Garante	L'interessato può rivolgersi al Garante Privacy italiano (garanteprivacy.it).

6. Misure tecniche di sicurezza implementate

Trasmissione sicura

- HTTPS obbligatorio su tutto il traffico (Railway gestisce TLS con Let's Encrypt)
- CORS: origini esplicite allowlist (dedomo.up.railway.app, dedomo.it) — no wildcard *
- Security headers: HSTS, X-Frame-Options DENY, X-Content-Type-Options nosniff, Referrer-Policy, Permissions-Policy

Autenticazione e sessioni

- Password hashate con bcrypt (passlib) — nessuna password conservata in chiaro
- Cookie sessione: HttpOnly, Secure, SameSite=None — durata 30 giorni
- Email di verifica al primo login; reset password via link monouso con scadenza
- Blacklist ~300 domini email usa-e-getta bloccati alla registrazione

Rate limiting (anti-brute-force, anti-abuso)

- Login / registrazione / reset password: max 10 richieste/minuto per IP
- OCR backend (OpenAI): max 5 richieste/minuto per IP
- Submit remoto ospite: max 20 richieste/minuto per IP
- Implementazione: sliding window in-memory con asyncio.Lock, zero dipendenze esterne

Database e storage

- MongoDB Atlas su AWS Frankfurt (UE) — i dati non escono dall'Unione Europea
- Accesso Atlas con URI dedicato + autenticazione utente/password
- Indici su tutte le chiavi di ricerca (user_id, token, email...) — no full table scan
-

Query tramite dizionari BSON (Motor) — impossibile SQL/NoSQL injection da input utente

Token ospite (remote check-in)

- Token UUID4 monouso generato per ogni link remoto — non indovinabile
- Scadenza configurabile; inviato solo all'indirizzo email indicato dall'host
- Il link non espone dati personali dell'ospite prima del submit
- Endpoint pubblico OCR: validato con lo stesso token del link remoto

7. Job automatici rilevanti per il GDPR (APScheduler)

Job / Frequenza	Azione / Riferimento GDPR
_gdpr_anonymize_old_data 1° del mese — ore 03:00 (Europe/Rome)	Anonimizza campi anagrafici in checkins >3 anni. Elimina remote_checkins completati/falliti >3 anni. Art. 5(1)(e) — limitazione della conservazione.
_process_scheduled_remote_checkins Ogni 2 minuti	Invia schedine ospiti autorizzati dall'host alle 23:59 del giorno di arrivo. Optimistic locking anti-double-send. Nessuna trasmissione senza autorizzazione host.
fetch_alloggiati_receipts Ogni ora	Recupera ricevuta PDF da Alloggiati Web dopo invio. Nessun dato personale aggiuntivo.
retry_failed_submissions Ogni 15 minuti	Riprova invii falliti (max 400 tentativi = ~14 giorni). Dopo esaurimento: record conservato ma non processato.

8. Informativa agli interessati (art. 13 GDPR)

- Punti di contatto dove l'ospite riceve l'informativa:
- Form check-in remoto (RemoteCheckin.jsx): box espandibile 'Informativa sul trattamento dei dati personali' — base giuridica art. 6(1)(c), finalità, retention 3 anni, diritti, link /privacy. Disponibile in 4 lingue: italiano, inglese, tedesco, francese.
 - Checkbox di presa d'atto: l'ospite deve confermare prima di poter inviare i dati. Senza spunta il pulsante 'Invia' resta disabilitato.
 - Pagina /privacy: policy pubblica accessibile da qualsiasi dispositivo, linkata dall'informativa.
- NOTA: il gestore (Titolare) deve integrare l'informativa con i propri dati di contatto, la sede, e il riferimento al proprio DPO (se nominato). Dedomo fornisce solo la struttura tecnica.

9. Terze parti e trasferimenti dati

Fornitore / Ruolo	Sede / Garanzie GDPR / Note
MongoDB Atlas storage dati principali	AWS Frankfurt (EU-WEST-1) — dati in UE. DPA disponibile su mongodb.com/legal/dpa
Railway hosting applicazione	Provider US — Standard Contractual Clauses UE. Nessun dato ospite processato fuori UE.
Resend email transazionali	Provider US — SCCs. Contiene solo: link check-in remoto, email benvenuto. Nessuna schedina PS.
OpenAI OCR documenti identità	Provider US — SCCs. Riceve immagine del documento; risponde con testo estratto. Richiede DPA: openai.com/policies/data-processing-addendum

Stripe
pagamenti abbonamento

Polizia di Stato / Alloggiati Web	Provider US — Titolare autonomo per dati billing. Non riceve dati personali degli ospiti.
Regioni / Comuni	IT — Autorità pubblica.
Ross 1000, Imposta Soggiorno	Destinatario istituzionale obbligatorio. Nessun DPA richiesto.
	IT — Autorità pubblica.
	Destinatario istituzionale obbligatorio. Nessun DPA richiesto.

10. Checklist adempimenti — stato attuale

Implementati tecnicamente

- ✓ Informativa art. 13 nel form ospite (4 lingue, box espandibile)
- ✓ Base giuridica art. 6(1)(c) documentata e comunicata all'interessato
- ✓ Trasmissione sicura: HTTPS + security headers + CORS ristretto
- ✓ Autenticazione robusta: bcrypt, sessioni sicure, reset monouso
- ✓ Rate limiting su endpoint critici (auth 10/min, OCR 5/min, remoto 20/min)
- ✓ Anonimizzazione automatica dopo 3 anni (APScheduler, 1° del mese ore 03:00)
- ✓ Cancellazione account completa (art. 17) con doppia conferma in UI
- ✓ Immagini documento OCR mai conservate — solo campi estratti
- ✓ Storage dati in UE (MongoDB Atlas, AWS Frankfurt)
- ✓ Payment_transactions: anonimizzate (non cancellate) alla chiusura account per obbligo fiscale

Adempimenti formali pendenti (richiedono azione umana)

- ✗ Registro dei trattamenti (art. 30 GDPR) — obbligatorio per trattamento non occasionale. Da redigere con consulente/avvocato privacy.
- ✗ Contratto DPA (art. 28) tipo da proporre a ogni gestore-cliente Dedomo che usa la piattaforma.
- ✗ DPA con OpenAI — obbligatorio per trattamento dati personali (immagini documenti) via API.
- ✗ Nomina DPO (Data Protection Officer) — valutare se obbligatorio in base alla scala operativa.
- ✗ DPIA (art. 35) — consigliata per trattamento sistematico di dati da documenti identità.
- ✗ Cookie policy e banner consenso — necessari se si usano cookie di profilazione o analytics.
- ✗ Rigenerazione password MongoDB Atlas — password precedente esposta in sessione di chat.
- ✗ Migrazione DNS dedomo.it → Railway — webhook Stripe e servizi live devono puntare a Railway.
- ✗ Pagina /privacy — aggiornare con dati di contatto del Titolare e data ultima revisione.
- ✗ Procedura di notifica violazioni (art. 33) — notifica al Garante entro 72h dalla scoperta.

11. Retention policy — riepilogo

Tipologia dato	Conservazione / Azione allo scadere
Schedine ospiti (checkins)	3 anni dalla data invio → anonimizzazione automatica campi anagrafici (job mensile)
Remote check-in completati/falliti	3 anni → eliminazione automatica (job mensile)
Sessioni utente	30 giorni → scadenza automatica; eliminate alla cancellazione account
Token email (reset/verifica)	24 ore → scadenza; eliminati alla cancellazione account
Token ospite (guest_tokens)	Validi fino alla cancellazione account del gestore
Dati account gestore	Fino alla cancellazione account → DELETE /auth/account

[elimina tutto](#)

Transazioni pagamento

Immagini documento (OCR)

Non eliminabili (obbligo fiscale 10 anni) → anonimizzate alla cancellazione account

MAI conservate — solo i campi estratti vengono salvati nel checkin

Cache guest page

Meteo 3h · eventi 24h · mercati 7g · attrazioni 48h → rigenerazione automatica

12. Riferimenti normativi

- Regolamento (UE) 2016/679 (GDPR) — eur-lex.europa.eu
- Garante Privacy italiano — garanteprivacy.it
- Art. 109 T.U.L.P.S. (R.D. 773/1931) — obbligo comunicazione arrivi alla PS
- D.Lgs. 286/1998 art. 7 — testo unico immigrazione
- D.Lgs. 79/2011 — Codice del Turismo (Ross 1000 / Turismo 5)
- Dedomo — responsabile tecnico: pama69@gmail.com